

## ÉTUDE DE CAS — SPOTIFY

---

Stratégie de gouvernance des données

# Livrable 2

## Politique de gouvernance des données

---

**Certification — RNCP 38777 — Ahmed Mehdi SEMAR**

Bloc 1 : Concevoir et piloter la politique de gouvernance des données de l'organisation.

# 1. Contexte, enjeux et portée

---

Au travers de sa plateforme de streaming, Spotify traite un volume considérable de données : contenus multimédias et leurs métadonnées, mais aussi données personnelles d'utilisateurs qu'il convient de protéger. Le diagnostic de maturité (Livrable 1) a mis en évidence un profil contrasté — une exploitation analytique mûre, mais une gouvernance transverse encore réactive, fragilisée par des silos hérités d'une croissance rapide.

La présente Politique de Gouvernance des Données (PGD) constitue le socle du cadre cible. Elle vise à standardiser la gestion des données à l'échelle de l'organisation afin de garantir la qualité, la conformité réglementaire, la confidentialité des utilisateurs, la sécurité, la disponibilité et un usage efficace de la donnée au service de la croissance et de l'innovation. L'absence d'un tel cadre expose Spotify à des sanctions pouvant atteindre 4 % du chiffre d'affaires annuel mondial sous le RGPD, ainsi qu'à une perte de confiance et à des inefficiences opérationnelles.

## Objectifs de la politique

- **Qualité.** Garantir des données exactes, complètes, cohérentes et à jour sur l'ensemble des départements et régions.
- **Conformité.** Assurer le respect du RGPD, du CCPA, du PCI-DSS et des autres réglementations applicables, locales comme internationales.
- **Confidentialité.** Protéger la vie privée des utilisateurs : minimisation, transparence, consentement et maîtrise de leurs données.
- **Accessibilité, intégration & disponibilité.** Casser les silos et fournir, à la bonne personne et au bon moment, des données fiables, intégrées et disponibles.

## Portée

Cette politique s'applique à la totalité des données collectées, traitées et stockées par Spotify dans le cadre de ses activités mondiales, et couvre tous les départements, régions et systèmes (data lakes, bases relationnelles, cloud). Elle concerne en particulier :

- les données utilisateurs (identité et usages sur la plateforme) ;
- les métadonnées des contenus proposés (titres, podcasts) ;
- les données marketing et d'engagement ;
- les données transactionnelles et de facturation (dont les données bancaires) ;
- les données internes (RH, financières, opérationnelles).

*L'adhésion de l'ensemble des collaborateurs à cette politique est une condition essentielle de l'atteinte des objectifs fixés.*

# 2. Principes fondamentaux de la gouvernance

---

Le cadre de gouvernance de Spotify est guidé par neuf principes, qui doivent être respectés dans toutes les activités de traitement des données.

- **Redevabilité (Accountability).** Établir une responsabilité claire sur les processus liés aux données. Les rôles de Data Steward et de DPO garantissent que la gouvernance respecte les normes organisationnelles, éthiques et légales.

- **Conformité (Compliance).** Assurer la conformité du traitement à toutes les réglementations pertinentes (RGPD, CCPA, PCI-DSS, IA Act...), différenciées par zone géographique, et procéder à des audits réguliers pour s'adapter à leur évolution.
- **Qualité (Data Quality).** Garantir des données exactes, complètes et fiables, via des audits réguliers et des processus de nettoyage et de remédiation.
- **Transparence (Transparency).** Rendre transparentes pour l'utilisateur toutes les activités de traitement de ses données personnelles ; avis de confidentialité détaillés et gestion du consentement obligatoires.
- **Minimisation (Data Minimization).** Ne collecter et ne traiter que les données strictement nécessaires à une finalité commerciale déterminée.
- **Droits des utilisateurs (User Rights).** Permettre l'accès, la rectification, la suppression et l'opposition de manière active (pas d'acceptation par défaut).
- **Sécurité (Data Security).** Faire de la sécurité une priorité : chiffrement des données sensibles (dont les données de paiement, conformité PCI-DSS), contrôles d'accès stricts et traçabilité des actions sur le SI.
- **Usage éthique (Ethical Use).** Surveiller les systèmes d'IA pour prévenir les biais algorithmiques et garantir l'explicabilité et l'équité des modèles.
- **Amélioration continue (Continuous Improvement).** Faire évoluer les pratiques au fil des changements réglementaires, technologiques et opérationnels, par des évaluations et révisions périodiques de la politique.

### 3. Gouvernance, rôles et responsabilités

La politique est mise en œuvre selon le modèle du Centre d'Excellence (CoE), structure fédérée qui concilie une gouvernance centrale forte (référentiels, outils transverses, conformité, animation de la communauté data) et l'agilité des équipes de domaine (production de leurs data products, qualité et documentation locales, application des politiques). Ce modèle est adapté à la taille mondiale de Spotify et au niveau de maturité constaté.

Une Direction Stratégique et Exécutive des Données (DSED), rattachée à la Direction générale, pilote ce centre. Les responsabilités principales sont réparties comme suit :

| Rôle                                 | Responsabilité principale                                                                                                                                                                      |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Chief Data Officer (CDO)</b>      | Porte la stratégie de gouvernance ; définit les politiques et standards ; aligne la donnée sur les objectifs métier ; anime les comités et les audits ; veille à un usage responsable de l'IA. |
| <b>Data Protection Officer (DPO)</b> | Garant de la conformité (RGPD, CCPA...) ; point de contact des autorités ; tient le registre des traitements ; pilote les DSR et la notification des violations sous 72 h.                     |
| <b>Comité de gouvernance</b>         | Instance transverse qui valide les politiques et processus, arbitre les sujets inter-départements et assure l'alignement stratégique.                                                          |
| <b>Équipe juridique (Legal)</b>      | Conseille sur la protection des données, encadre les contrats fournisseurs et transferts, gère les risques réglementaires.                                                                     |
| <b>Head of Engineering</b>           | Garantit une infrastructure data évolutive, fiable et sécurisée (collecte, stockage, traitement) conforme aux politiques.                                                                      |

| Rôle                                | Responsabilité principale                                                                                                                                    |
|-------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Data Stewards</b>                | Relais entre métiers et DSI ; garants de la qualité, de la cohérence et de la conformité des données de leur domaine ; appliquent les règles de gouvernance. |
| <b>Data Owners (par domaine)</b>    | Responsables d'un périmètre de données : exposent, documentent et arbitrent les usages de leurs sources.                                                     |
| <b>Product Managers / Marketing</b> | Exploitent la donnée pour le produit et les campagnes, dans le respect des règles de qualité et de confidentialité.                                          |

## Matrice RACI synthétique

**Légende** : R = Responsable (exécute) · A = Accountable (décide / rend compte) · C = Consulted (avis) · I = Informed. Extrait synthétique ; la RACI détaillée est tenue à jour dans le catalogue de données.

| Tâche clé                                           | CDO | DPO | DS | DE | Séc. | Legal | Métiers |
|-----------------------------------------------------|-----|-----|----|----|------|-------|---------|
| Rédiger les politiques (qualité, accès, vie privée) | A   | C   | R  | I  | C    | C     | I       |
| Définir les SLO et standards de qualité             | A   | I   | R  | C  | I    | I     | C       |
| Tenir le registre des traitements                   | C   | A/R | C  | I  | I    | C     | I       |
| Industrialiser les demandes de droits (DSR)         | I   | A/R | C  | R  | I    | C     | I       |
| Gérer le consentement (plateforme & preuves)        | C   | A   | C  | R  | I    | C     | I       |
| Mettre en place RBAC/ABAC & masquage PII            | A   | C   | C  | R  | R    | I     | I       |
| Déployer le catalogue & le lineage                  | A   | I   | R  | R  | C    | I     | I       |
| Mettre en place le comité de gouvernance            | A/R | C   | C  | I  | C    | C     | I       |
| Programme d'audit interne (trimestriel)             | A   | C   | C  | I  | C    | C     | I       |
| Plan de formation & communication                   | A   | C   | C  | I  | I    | I     | R       |

DS = Data Steward · DE = Data/Analytics Engineer · Séc. = Sécurité IT. Une tâche = un A unique et au moins un R, conformément à la règle RACI.

## 4. Conformité et protection des données

La conformité est intégrée à chaque phase du traitement. Spotify met en place les processus et outils nécessaires au respect des exigences ci-dessous.

### 4.1 RGPD (Union européenne)

Du fait de sa domiciliation suédoise, Spotify applique par défaut le RGPD à l'ensemble de ses utilisateurs. Les exigences clés sont :

- **Finalité & minimisation.** Ne collecter que les données nécessaires à l'objectif visé.
- **Transparence & consentement.** Informer clairement l'utilisateur dès la collecte et recueillir un consentement explicite.

- **Droits des personnes.** Permettre l'accès, la rectification, la suppression et l'opposition, et y répondre dans les meilleurs délais.
- **Conservation.** Limiter la durée de conservation en base active ; détruire, anonymiser ou archiver ensuite.
- **Sécurité & gestion du risque.** Mesures adaptées à la sensibilité des données et gestion stricte des habilitations.
- **Notification de violation.** Notifier l'autorité sous 72 heures, et les personnes concernées en cas de risque élevé.

Une vigilance particulière s'applique aux données sensibles (origine raciale ou ethnique, opinions politiques, etc.), dont le traitement est par principe interdit sauf exceptions légales (consentement exprès notamment).

## 4.2 CCPA (Californie, États-Unis)

Le CCPA retient une définition large des informations sensibles et garantit quatre droits principaux, appliqués par commodité à l'ensemble des utilisateurs américains :

- connaître les informations personnelles collectées, utilisées, partagées ou vendues ;
- obtenir la suppression de ses informations personnelles ;
- refuser la vente de ses informations personnelles ;
- ne subir aucune discrimination de prix ou de service en cas d'exercice de ces droits.

## 4.3 PCI-DSS 4.0 (données de paiement)

Cette norme garantit un environnement sécurisé pour le traitement des données de cartes de paiement :

- **Sécurité du réseau.** Infrastructure protégée et pare-feu maintenus.
- **Protection des données.** Chiffrement et stockage sécurisé des données de carte.
- **Contrôle d'accès.** Accès restreint aux seuls personnels autorisés.
- **Surveillance & tests.** Supervision des accès et tests réguliers des défenses.
- **Politique de sécurité.** Politique de sécurité de l'information maintenue dans le temps.

## 4.4 Ouverture multi-juridiction

Opérant dans plus de 180 pays, Spotify ne peut limiter sa conformité aux trois cadres ci-dessus. La politique pose le principe d'une conformité « par juridiction » et d'une veille réglementaire active intégrant notamment le PDPA (Singapour), la LGPD (Brésil), la PIPEDA (Canada), ainsi que les cadres émergents sur l'IA (IA Act) et la modération de contenu (Digital Services Act). Lorsqu'un utilisateur relève de plusieurs textes, ce sont les dispositions les plus protectrices qui s'appliquent. L'application des règles est automatisée selon la zone afin de tenir l'échelle.

# 5. Qualité, sécurité, accessibilité et disponibilité

---

## 5.1 Qualité des données

- **Standardisation.** Standards clairs et référentiels partagés (devises, composantes géographiques, identifiants).
- **Assurance qualité.** Processus de nettoyage, validation et surveillance continue de l'exactitude, l'exhaustivité et la cohérence.

- **Métadonnées.** Documentation des données (techniques et métier), sensibilité et utilisateurs autorisés.
- **Source unique de vérité (SSOT).** Établir un référentiel maître (MDM) pour les données critiques de l'entreprise.

## 5.2 Sécurité des données et gestion des risques

- **Chiffrement & stockage sécurisé.** Données sensibles chiffrées ; mesures de sécurité testées régulièrement.
- **Contrôle d'accès.** Accès strictement basé sur les rôles (RBAC) et le moindre privilège.
- **Audit.** Vérification régulière que les politiques sont effectivement appliquées.

## 5.3 Accessibilité et intégration

- **Rupture des silos.** Environnement de données intégré au service de la collaboration et de l'innovation.
- **Outillage.** Catalogue de données pour organiser et faciliter la découverte des actifs ; synchronisation et contrôles d'intégration.

## 5.4 Disponibilité

La disponibilité de la donnée — souvent négligée derrière la qualité et la sécurité — est un axe à part entière. La politique fixe des niveaux de service (SLA/SLO) sur l'accès aux données critiques, vise la réduction des goulots d'étranglement liés aux silos par un accès self-service gouverné, et impose des runbooks d'incident assortis d'objectifs de temps de rétablissement (MTTR). L'enjeu est de garantir un accès fiable et continu aux données pour les équipes qui en dépendent, sans compromettre la sécurité.

# 6. Mesure et amélioration continue

---

La réussite de la politique est mesurée par des indicateurs clés (KPI) qui guident l'amélioration continue :

- **Qualité.** Réduction des incohérences, erreurs et doublons ; complétude et fraîcheur des jeux de données critiques.
- **Conformité.** Absence de sanctions réglementaires ; délais de traitement des demandes de droits ; couverture du registre des traitements.
- **Efficacité opérationnelle.** Réduction des délais d'accès et des frictions liées aux silos.
- **Confiance des utilisateurs.** Transparence accrue et baisse des plaintes relatives à l'usage des données.

**Conclusion.** Cette politique pose le cadre — principes, rôles et exigences — d'une gouvernance unifiée conciliant innovation et conformité. Sa traduction opérationnelle (modèle CoE, outillage, pilote, formation, audits et registre des risques) fait l'objet du plan de mise en œuvre (Livrable 3).